



Centrifuge September Updates Audit Report

Prepared by [Burra Security](#)

Version 1.0

Researchers

fuzious

Taridoku

Alex Filippov

September 30, 2026

Contents

1 About Burra Security 2

2 Disclaimer 2

3 Risk Classification 2

4 Protocol Summary 2

5 Audit Scope 2

6 Executive Summary 3

7 Findings 4

7.1 Medium Risk 4

7.1.1 OpsGuardian can permanently poison Hub asset registrations 4

7.2 Low Risk 5

7.2.1 Anyone can permanently bind an asset to 0 decimals by registering it before its decimals
are set 5

1 About Burra Security

Burra Security offers security auditing and advisory services with a special focus on cross-chain and interoperability protocols and their integrations. Learn about us at burrasec.com.

2 Disclaimer

A smart contract security review can never verify the complete absence of vulnerabilities. This is a time, resource, and expertise-bound effort where we try to find as many vulnerabilities as possible. We can not guarantee 100% security after the review or even if the review will find any vulnerabilities. Subsequent security reviews, bug bounty programs, and on-chain monitoring are recommended.

3 Risk Classification

	Impact: High	Impact: Medium	Impact: Low
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

4 Protocol Summary

The audited changes target Centrifuge's cross-chain messaging layer, its gas pricing, and the Hub and Spoke contracts that manage tokenized pools across networks.

The Gateway now reads message framing (length, pool ID, source chain) from the MessageProcessor rather than the ops-filed GasService. The GasService prices each adapter's receive path through the new IAdapter-GasService.receiveCost, which the Axelar, Chainlink, Hyperlane, LayerZero and Standby adapters reach via MultiAdapter.messageGas(). The ChainlinkAdapter adopts CCIP 2.0 GenericExtraArgsV3, letting a lane request faster-than-finality delivery.

On the Hub, unauthorizeSpokeCall routes through the StdHubPolicy pool policy, and the ShareClassManager and Holdings counters widen to uint256. On the Spoke, PoolEscrow becomes Escrow, absorbing the misc escrow base, and the transfer hooks no longer block memberlist updates for pool escrows.

5 Audit Scope

The scope of the audit is the following diffs:

- the diff between commit 58e0ddfe0af7e5c683e56228885a6aabedadff6c and commit 976315f1bece07e1d3559313933166d2561dd93e (PR #387)
- the diff between commit 1b0e3f1d36d2b37d0d90669f703c415c7845a95e and commit 730ed753e4a4b704f03e40c46373e6d58f8ff6ea (PR #398)
- the diff between commit c818db95ba47861da85028ab8a4c3d5874155592 and commit 7fbcc524d6f0b33d9d85d7160d9c078b43f7cf72 (PR #399)
- the diff between commit 7fbcc524d6f0b33d9d85d7160d9c078b43f7cf72 and commit 2738072e7d0d8ca90b6726151358e47fcf0486c6 (PR #408)
- the diff between commit b56d13c9ba2944887c4fe18ca5ce49e70859a138 and commit c818db95ba47861da85028ab8a4c3d5874155592 (PR #410)

- the diff between commit 2738072e7d0d8ca90b6726151358e47fcf0486c6 and commit abcdc4e85b34c54ef9c78189b865d9f10e9194bb (PR #415)
- the diff between commit 81d1cff07062f44000f2924009b450b571896414 and commit e1cac8ca96efc34a6f3cb0a7f565b9adccc46780 (PR #422)

for all the files in:

```
src/**
```

6 Executive Summary

Over the course of 2 days, the Burra Security team conducted an audit on the [Centrifuge September Updates](#) smart contracts provided by [Centrifuge](#). In this period, a total of 2 issues were found.

Summary

Project Name	Centrifuge September Updates
Repository	protocol-internal
Commit	e1cac8ca96ef...
Fix Commit	74e16461ca39...
Audit Timeline	23rd September - 24th September
Methods	Manual Review

Issues Found

Critical Risk	0
High Risk	0
Medium Risk	1
Low Risk	1
Informational	0
Gas Optimizations	0
Total Issues	2

Summary of Findings

[M-1] OpsGuardian can permanently poison Hub asset registrations	Resolved
[L-1] Anyone can permanently bind an asset to 0 decimals by registering it before its decimals are set	Resolved

7 Findings

7.1 Medium Risk

7.1.1 OpsGuardian can permanently poison Hub asset registrations

Target: [OpsGuardian.sol#L67-L73](#), [MultiAdapter.sol#L87-L108](#), [SpokeRegistry.sol#L304-L317](#), [MessageProcessor.sol#L102-L106](#), [HubRegistry.sol#L47-L54](#)

Severity:

- Impact: High
- Likelihood: Low

Description: `OpsGuardian.setAdapters` lets the ops Safe replace an existing global adapter set with arbitrary adapter addresses. A compromised ops Safe can therefore install its own adapter and submit a forged `RegisterAsset` message from the remote chain. A one-adapter set with a threshold of one can call `MultiAdapter.handle` directly, so no real cross-chain delivery or adapter wiring is required.

Asset IDs are predictable because `SpokeRegistry` assigns them using an incrementing counter. The attacker can pre-register the next asset ID on the Hub with incorrect decimals. When the real asset is registered, `HubRegistry.registerAsset` reverts with `AssetAlreadyRegistered`.

`HubRegistry` has no function to update or remove an asset registration, so even Root cannot correct the entry. The asset can never be registered with its real metadata and cannot be used safely on that Hub. Replacing the adapter set or revoking the ops Safe does not recover it. Because several core contracts hold the `HubRegistry` address as an immutable dependency, recovery requires replacing core contracts.

Recommended Mitigation: Consider allowing `OpsGuardian` to set a chain's global adapters only while `activeSessionId` is 0.

Centrifuge: Fixed in [centrifuge/protocol-internal#425](#).

BurraSec: Fix looks good.

7.2 Low Risk

7.2.1 Anyone can permanently bind an asset to 0 decimals by registering it before its decimals are set

Target: [Spoke.sol#L84-L113](#), [SpokeRegistry.sol#L303-L318](#), [HubRegistry.sol#L47-L55](#)

Severity:

- Impact: Medium
- Likelihood: Low

Description: `Spoke.registerAsset` is permissionless and reads the asset's decimals at call time. Some tokens report 0 decimals until their issuer finishes setting them up:

- An OpenZeppelin `ERC6909Metadata` ID the issuer has not created yet returns 0 decimals and empty strings rather than reverting.
- Circle's `FiatToken`, used by USDC, EURC and the Bridged USDC Standard, keeps decimals in [storage](#). Its [proxy](#) takes no initialization data, and Circle's [deploy script](#) calls `initialize` in a later transaction. An attacker can submit the registration between the proxy deployment and its initialization.

An attacker who registers such a token first binds it to an asset ID in `SpokeRegistry`, and the destination `HubRegistry` stores 0 decimals for that ID. Registering the token again later resends the same ID, which the Hub rejects with `AssetAlreadyRegistered`. `HubRegistry` has no way to correct the entry, even for Root. The Hub values holdings with the stored decimals, so a 6-decimal asset would be overvalued by 10^6 , and the asset can never be used on that Hub.

This is a regression in v3.3. Before [47c9467](#), `Spoke.registerAsset` rejected fewer than 2 decimals and `HubRegistry` treated 0 decimals as unregistered. The out-of-scope item on mutable decimals makes a bad registration "the registering pool's error", but here a third party registers the token before its decimals are final, and the pool can neither prevent nor undo it. The DoS is permanent, and fixing it requires redeploying `HubRegistry` together with the core contracts that hold it as an immutable dependency.

Recommended Mitigation: Consider adding a Root-only way to correct asset decimals in `HubRegistry`.

Centrifuge: Fixed in [centrifuge/protocol-internal#425](#).

BurraSec: Fix looks good.